



Work as ITSO in an 'Agile' company.

November 2018

Gentlemen agreement between us...



- × No **buzzword** usage on my side!
- × No sale pitch or magic box pitch too!
- × I hope a real exchange between us about:
 - × Agile context implications.
 - × Issues & challenges meet/achieved.

Feel free to interrupt me to ask any questions 😊

Agenda



- × The changes brought by agile methodologies.
- × The impacts for the security department.
- × A new job opportunity for an ITSO.
- × The new world of the ITSO.
- × Conclusion.

Greeting (raise your hand at each question).



- × How many 'IT Security Officer' are present?
- × How many 'CISO' are present?
- × How many 'Scrum Master' are present?
- × How many 'Product Owner' are present?

The changes brought by agile methodologies.



- × The applications are developed more quickly using Sprint of an average of two weeks (Sprint approach used here for the example).
- × The applications are released and deployed with a higher frequency.
- × Heavy usage of automation for non-human required task.
- × Specification move from '*documents*' to concise User Stories.
- × Business people closely lead the features developed and released...

The changes brought by agile methodologies.



- × Introduction of a flat hierarchy (or no – hierarchy) in the project team.
- × Focus on human interaction between all project members.
- × Project team is composed of people handling all application layers.
- × Focus made on pragmatism, only valuable elements are taken into account.

The changes brought by agile methodologies.



- × Every people's work and issues meet become visible and known by all in order to address issues quickly.
- × Mass usage of new technologies/tools to support agility and the productivity implied/wanted.
- × Teams want more control on the provisioning and deployment process of their application.

The impacts for the security department.



- × Provide the technical environment needed by the agile approach.
- × Toolbox of the agile teams:
 - × Need to ensure the security of all these tools (patching,...).
 - × Need to provision these tools according to the company's context.
 - × Need to define usage processes.
 - × Need to define communication flow with Internet.
 - × Need to define logging, audit trail, monitoring...
 - × Need to define and track user/authorization provisioning
 - × ...

The impacts for the security department.



- × Usage of methodologies unknown by people in charge of the security.
- × Usage of technologies unknown by people in charge of the security.
- × When an SOC is used, it requires the definition of new user cases in order to detect a malicious member from the agile team.
- × The same remark is applicable about CSIRT on the capacity to analyse/reverse the application developed with latest technologies used.

The impacts for the security department.



- × Release cannot be blocked by the Security Department any more due to the fact that the 'final intrusion test' was not performed because deployment of a high business value app cannot be blocked...
- × The number of uncontrolled released and code deployed on production will imply that the Security Department will always be in 'Reactive' mode in case of security issues.

The impacts for the security department.



× It's really not easy but the most difficult part is in front...

The impacts for the security department.



- × How do I manage the famous intrusion test performed before every release in production according to the new frequency of release?
- × How do I perform a code review on the application according to the new implementation speed?
- × How do I manage the new technologies used? The new 3rd party used?

The impacts for the security department.



- × How do I manage the security requirements in this agile model?
- × How do I ensure the environment provisioned by the agile team are secure or follow the company 'historical' policies?
- × How do I update my security devices configuration (ex: WAF) to the new released version of the application (new endpoints, new I/O parameters...) according to the new deployment frequency?



A new job opportunity for an ITSO.



- × Even for developers, agile was a big bang a few years ago...
- × ITSO and Sec. Dept. are perceived as a blocking point due to the heavy/long processes and the '*You are not allowed to do that*' motto.
- × Agile can be leveraged to move from the **IT Security Officer** position to the **IT Security Champion** one, now perceived by the agile team as a security reference providing *solutions/ideas* instead of *problems*.
- × It is possible but an evolution is needed...

A new job opportunity for an ITSO.



- × Agile teams really need pragmatic supports from the security guy to identify and address security weaknesses, It's not their job and they are busy on the business part!
- × Most of ITSO have a developer or infrastructure background that can be leveraged to provide this support.
- × The evolution to perform is to include the ITSO directly in the agile projects in order to allow him to handle, with the team, all security-related topics.

A new job opportunity for an ITSO.



- × The evolution will require a refactoring of the skills and mindset of the ITSO to add several upgrades...



A new job opportunity for an ITSO.



- × Understand the agile methodology used (processes & philosophy).
- × Obtain an offensive mindset to identify abuse cases in User Stories presented to him.
- × Understand the technologies stack used by the teams in order to be able to provide countermeasures proposals along prototypes and secure provisioning recipes.

A new job opportunity for an ITSO.



- × Understand and adapt the automation tools/scripts used by the teams from a security point of view or create new one.
- × Don't be afraid to say, 'I don't know but I will deep dive to find a solution or learn this topic...'.
- × Don't be afraid to fail during the proposal of countermeasures or provision recipes ➔ it is human to miss or create a weakness...

A new job opportunity for an ITSO.



- × Become able to perform a security assessment of the content of the Sprint.
- × Spread security knowledge between all agile team members according to weaknesses found during security assessment.
- × Implement protection against the weaknesses found, in case of needed.
- × Do pragmatic security that take in account the culture and the constraints of agile teams.

The new world of the ITSOC.

- × The new job of the ITSOC will be composed by these kinds of tasks...

Source: <http://agilemanifestoposter.com/>



The new world of the ITSOC.



- × Identify abuse cases during the definition of each User Story:
 - × Understand the business feature beneath the US.
 - × Identify attacks that can be leveraged against this feature.
 - × Identify potential applicable countermeasures.
 - × Derive the abuse cases as 'Acceptance Criteria' in the US.
 - × Identify the countermeasures that can be applied.

The new world of the ITSOC.



- × Identify and provide the required materials to agile teams to put in place the countermeasures against identified attacks:
 - × Code snippet,
 - × Libraries,
 - × Frameworks,
 - × Configuration snippet,
 - × Deployment and provisioning secure recipes/descriptors.
 - × ...

- × Prefer the usage of a WIKI to share and centralise the information.

The new world of the ITSOC.



- × Provides supports to agile teams about the attacks identified and proposed countermeasures:
 - × Internal awareness training session,
 - × Technical explanation of the countermeasures,
 - × Limitations of the countermeasures.

The new world of the ITSEC.



- × Provides to the agile teams the materials to continuously monitor the security of the whole application by leveraging Continuous Integration and Continuous Delivery:
 - × Add security validation steps in the build process.
 - × Review these validation steps with the team to ensure they really add values and refactor them if needed → Identify the friction points.
 - × Review/adapt/filter the reports generated with the team to it explain it content to them.

The new world of the ITSOC.

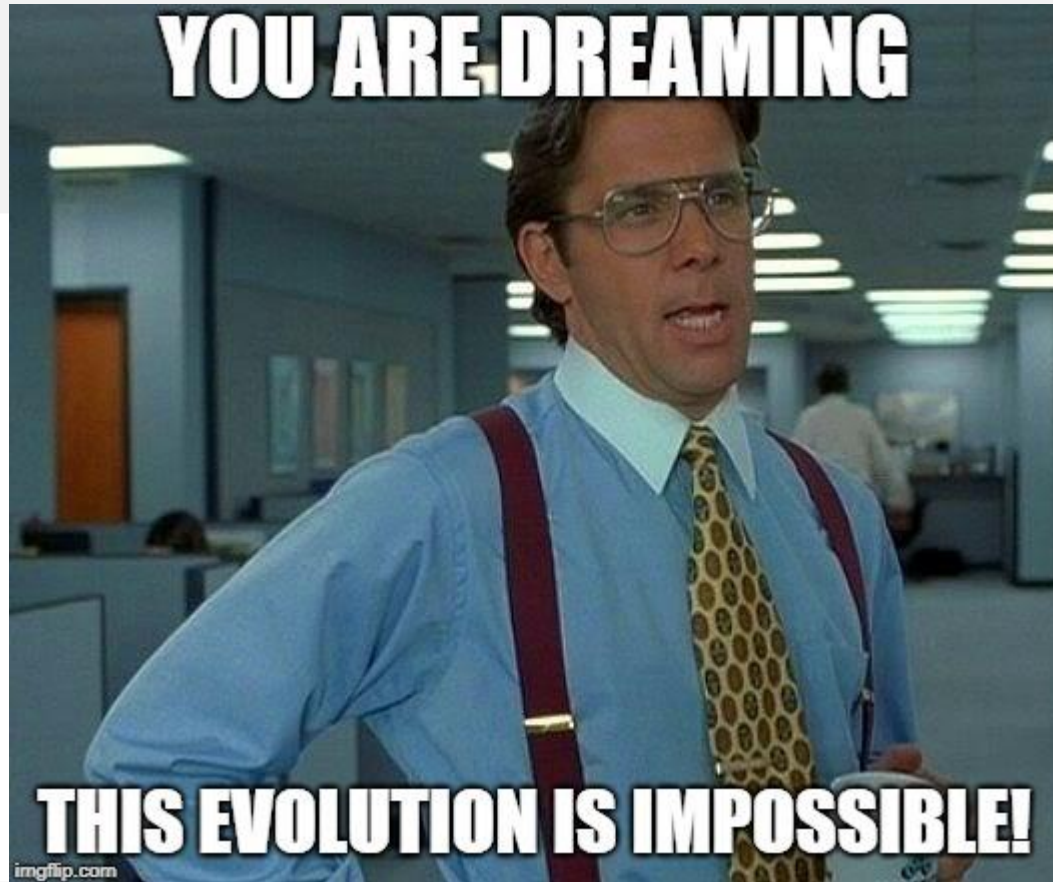


- × Perform security assessment on the content of the sprint:
 - × Apply a dedicated and scoped intrusion test or code review.
 - × Based on the assessment then adapt or add new security checks the build process.
 - × Same idea about awareness training.
 - × Identify new countermeasures to add or existing one to refactor.
 - × Present the results to the agile teams.

The new world of the ITSOC.



- × Become able to challenge the assessment report of a security firm:
 - × Challenge auditors for non-real or abusive issues raised.
 - × Challenge the fixation recommendations from the auditors in order to question their efficiency, quality and feasibility.
 - × Help agile teams to really evaluate the severity of an issue.
 - × Explains the issues raised to the agile teams and help to fix them.



Not possible or secretly not wanted?



- × If development teams have achieved, across years, to assimilate agile related methodologies, technologies and environment, so why not you?
- × By the way, we start to meet this profile of ITSC on some client...
- × It's not a matter of possible or not, it's unfortunately the reality. If you can't integrate into agile projects:
 - × You will be simply bypassed!
 - × You will continue to work in reactive mode with the associated bad condition (stress, pressure, urgency...).

Conclusion



- × Agile methodologies have changed the speed and the frequency of the software's delivery.
- × This change on productivity speed has impacted the historical way of doing security.
- × The role of *ITSO* must evolve to a *Application Security Champion* role in order to allow the integration of the security into agile projects and teams core.
- × Agile is an new job opportunity for ITSO not a fatality...

Few words to keep in your mind...



- × It is not a race, as few years ago for developers, it has taken time to assimilate these changes...
- × Take the time needed according to your company and security team culture.
- × One little step after one is the key of the success!

